

-

File No.: EXP202310796

## RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for the Protection of Data and based on the following

### BACKGROUND

FIRST: On July 13, 2023, A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for the Protection of Data.

The complaint is directed against AYUNTAMIENTO DE MONTEMAYOR DE PILILLA, with NIF P4709400H (hereinafter, Ayuntamiento or the complained party).

The reasons on which the complaint is based are as follows:

(...).

On \*\*\*DATE.1, the Mayor of the aforementioned municipality published a statement on the public platform "Bando Móvil" (accessible to anyone who downloads the application and to all residents of the municipality), regarding the complainant, in which a series of defamations and falsehoods were made, (...).

The complainant indicates that they sent (...) and that the publication of such data affecting their privacy and health was made without the consent of the Mayor or the Ayuntamiento for its use and dissemination.

The following documents are provided:

a) Statement from the Mayor of Montemayor de Pililla, dated \*\*\*DATE.1;

b) Image of the publication on the 'Bando Móvil' platform, dated \*\*\*DATE.1

(...).

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), on August 2, 2023, the aforementioned complaint was forwarded to the complained party, and this was reiterated on two more occasions, on August 14, 2023, and October 4, 2023, for them to proceed with its analysis and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The notice sent by postal mail on August 14, 2023, was received by the Ayuntamiento on August 30, 2023.

However, no response was received to this notice.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

THIRD: On October 13, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On January 30, 2024, the Director of the Spanish Agency for the Protection of Data decided to initiate sanctioning proceedings against the complained party for the alleged infringement of Article 5.1.f) of the GDPR, Article 9 of the GDPR, and Article 32 of the GDPR, the latter classified under Article 83.4 of the GDPR and the first two under Article 83.5 of the GDPR.

FIFTH: On February 16, 2023, in response to the initiation agreement, the following statements were submitted by the complained party:

"This Ayuntamiento has not responded to the initial notice of the complaint with the requirements made by the AEPD for its analysis and to send information, due to the lack of a stable technical official, as during the period of the events, and in a few months, they have served (...). Therefore, there have been periods of time when the Ayuntamiento has lacked (...), who could advise on data protection regulations and fulfill the requirements.

Regarding the Bando Móvil, it informed about a specific situation of the service of (...), which the Ayuntamiento must provide to the citizens and which on the indicated days was not presented, due to the absence of (...). The means by which it was informed was through a Bando, which is an administrative act, not normative, under the competence of the mayor, consisting of a statement or information directed to the citizens, in this case, informing the neighbors of the lack of the Secretariat service.

This competence is established in Article 21.1, e), Article 124.4, g) of Law 7/1985, of April 2, Regulating the Bases of Local Regime.

The complainant indicates that the Bando móvil contained a series of defamations and falsehoods, which is not true, as the facts indicated in the Bando are true and can be demonstrated. I refer to the files of the corresponding administrations. However, I consider that this is not the issue raised in a sanctioning file for personal data protection. The complainant should have used another legal avenue to claim for defamation and falsehood. The complainant is using the sanctioning administrative route of the AEPD as a means to harm the Ayuntamiento of Montemayor de Pililla.

The indication made in the Bando of the complainant's absence from the workplace due to "(...)" is a statement regarding the service provision relationship, by which it is informed that (...) was due to those causes.

The expression "(...)" does not violate their right to privacy or health, as nothing is indicated about a possible illness, or medical assistance for themselves or another person, etc., but rather it is an expression that informs about the justification for the complainant's absence from the Ayuntamiento. Said Bando was issued within the powers of the mayors, who perform

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

3/21

the senior management of all personnel, as established by Article 21.1, h) of the Law on the Bases of Local Regime.

The facts reported by the claimant do not violate the right to protect their personal and health data, as no name is mentioned, only the position of the Town Hall, and no health data is indicated. Therefore, the data has been processed in a manner that guarantees adequate security of their personal data, and there is no lack of technical and organizational measures since no personal or health data has been disclosed.

There has been no violation of health-related data, as the expression "(...)" does not reveal any health data and refers to a justification of a labor nature, which resulted in the claimant's absence from work. Furthermore, should the provision be considered applicable to the reported fact, it would not apply as the processing is necessary for the fulfillment of obligations and the exercise of specific rights of the data controller or the data subject in the field of labor law and social security and protection, to the extent that it is authorized by the law of the Union of Member States or a collective agreement under the law of Member States that establishes adequate guarantees for the respect of fundamental rights and the interests of the data subject. As established by Article 5.2. b) of the Regulation.

There were appropriate technical and organizational measures in place to ensure an adequate level of security relative to the risk. The reported facts do not imply a lack of technical or organizational measures; moreover, the GDPR does not establish a list of such measures.

The claimant was aware, by virtue of their position, of the existence of information regarding the processing of personal data by the Town Hall and how to exercise their rights, as this information is available on the Town Hall's website. However, they did not exercise the rights available to them, such as the right to rectification, erasure, restriction of processing, and objection.

There is no infringement of personal data protection regulations, and therefore no sanction is applicable."

SIXTH: On April 17, 2024, a proposal for resolution was sent to the respondent party, proposing the following:

That the Director of the Spanish Agency for Data Protection declare that the Town Hall of Montemayor

de Pililla has infringed the provisions of Article 5.1.f) of the GDPR, Article 9 of the GDPR, and Article 32 of the GDPR, as classified in Article 83.4 of the GDPR for the latter and in Article 83.5 of the GDPR for the first two.

That the Director of the Spanish Agency for Data Protection order the Town Hall of Montemayor de Pililla, pursuant to Article 58.2.d) of the GDPR, to notify this Agency within one month of the adoption of measures that respect the principle of integrity and confidentiality established in Article 5.1 f) of the GDPR, ensuring adequate security of personal data to prevent violations of the principle of integrity and confidentiality of personal data, as required by Article 5.1 f) of the GDPR, especially health data, which is considered particularly sensitive, in accordance with Article 9 of the GDPR and the adoption of necessary measures to prevent such events from recurring, in accordance with Article 32 of the GDPR.

SEVENTH: In response to the proposal for resolution dated April 17, 2024, the respondent party submitted allegations in which, in addition to what was indicated in their written allegations regarding the initiation of the procedure, they state the following:

"I affirm and ratify the allegations made in writing dated 02/15/2024, against the resolution of initiation of the sanctioning procedure, considering them reproduced in these present allegations.

First.- The expressions contained in the Town Hall's mobile bulletin do not affect the privacy or health data of the claimant.

(...)

This Bulletin was issued within the powers of the Mayors, who hold the senior management of all personnel, as established by Article 21.1, h) of the Law on the Bases of Local Regime.

Therefore, there has been no infringement of data protection regulations, as the Town Hall had the legitimacy to process the mentioned information, and the consent of the respondent party was not necessary. The dissemination of data was of an informative nature for the citizens of the municipality, so the initiation of the sanctioning procedure was not warranted, as established by Article 58.2 of the GDPR.

Second.- Regarding the possible infringements established in the Proposal for Resolution of the sanctioning procedure.

1.- Article 5.1, f) of the GDPR. Principles relating to the processing of personal data.

The facts reported by the claimant do not violate the right to protect their personal and health data, as no name is mentioned, only a service of the Town Hall that could not be provided due to lack of personnel, and no health data of the claimant is indicated.

Therefore, the data has been processed in a manner that guarantees adequate security of their personal data, and there is no lack of technical and organizational measures since no personal or health data has been disclosed.

2.- Article 9 of the GDPR. Processing of special categories of personal data.

(...)

3.- Article 32 of the GDPR. Security of processing.

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

5/21

There were appropriate technical and organizational measures in place to ensure a level of security adequate to the risk. The reported facts do not imply a lack of technical or organizational measures; moreover, the GDPR does not establish a list of such measures.

(...)

Fourth.- The application of sanctions is not warranted.

There is no infringement of personal data protection regulations, therefore no sanctions are warranted.

Fifth.- Proposals for security measures.

Regarding the imposition of the adoption of appropriate measures that respect the principles of integrity and confidentiality, it should be noted that the GDPR does NOT establish a list of security measures applicable according to the data being processed, but rather states that technical and

organizational measures appropriate to the risk involved in the processing will be applied.

However, despite the lack of a list of security measures, the claimed City Council will establish security measures taking into account the state of the art, the costs of implementation, the nature, scope, context, and purpose of the processing, and the risks of probability and severity for the rights and freedoms of the data subjects.

Proposed security measures to adopt:

1.- Description of the technical and organizational security measures.

Guided by Royal Decree 311/2022, of May 3, which regulates the National Security Scheme, the following protective measures will be applied:

- Protection of facilities and infrastructures
- Personnel management
- Protection of equipment
- Protection of communications
- Protection of information media
- Protection of software applications
- Protection of information
- Protection of services
- Protection of email
- Protection of web services and applications
- Protection of web browsing

2.- Application of the security measures contained in the personal data protection guides: personal data protection and local administration strategic security guide for local entities, guide for local entities with fewer than 2,000 inhabitants.

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](http://sedeagpd.gob.es)

6/21

- Identification and authentication of users
- Only those local users who can log in will exist on a given machine.
- Under no circumstances will access passwords to the machine be written down near the desk or in any location where their purpose can be identified.
- The administrator account will only be in the hands of the information security officer and must be changed every time it needs to be known by another person for technical reasons, for example, from the technical service.
- Changes in civil servant personnel will entail changing the passwords for all equipment, services, and systems to which the outgoing personnel had access.
- After a period of inactivity, the equipment must be configured to automatically lock, requiring re-entry of the access key, which means that, in the event of an eventual abandonment of the workstation, the equipment will not remain accessible indefinitely.
- If there are shared folders, special attention will be paid to the security tab of the files and folders, which indicates their availability for local users and for those accessing from the network.

3.- Training and awareness.

Periodically, the Provincial Council of Valladolid will organize training and updating courses on information security, which will be mandatory for at least the Municipal Information Systems Security Officer.

Sixth.- Commitments of the City Council of Montemayor de Pililla.

1.- The Mobile Bulletin subject to the complaint has been removed.

2.- Publication of the Institutional Declaration of the City Council regarding the commitment to Personal Data Protection. Attached is the commitment document.

3.- Compliance with Personal Data Protection regulations (GDPR and LOPDGDD).

In view of all actions taken by the Spanish Agency for Data Protection in this procedure, the following

facts are considered proven,

## PROVEN FACTS

FIRST: On \*\*\*DATE.1, the Mayor of the aforementioned municipality published the following on the public platform "Bando Móvil":

“\*\*\*DATE.1

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/21

(...).

(...).

(...).”.

## FUNDAMENTOS DE DERECHO

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

### Preliminary Issues

In the present case, the complainant states that on \*\*\*DATE.1, the Town Hall of Montemayor de Pililla published on the public platform "Bando Móvil" a statement containing a series of defamations and falsehoods regarding them, detailing that the (...).

The complainant indicates that they sent (...) and that the publication of such data affects their privacy and health, without having consented to its use and dissemination.

The respondent carries out this activity in their capacity as the data controller, as they are the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR:

“‘data controller’ or ‘controller’: the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for their designation may be provided for by the law of the Union or of the Member States.”

III

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/21

### Response to the Allegations Presented by the Respondent

Before proceeding to respond to the allegations presented by the respondent, it should be noted that Article 4 of the GDPR defines personal data as “any information relating to an identified or identifiable natural person (‘the data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic,

mental, economic, cultural, or social identity of that natural person.”

1. The respondent has stated that the information contained in the mobile bulletin subject to the complaint does not affect the right to the protection of personal data, as it does not mention the name of the complainant. However, it should be noted that the complainant (...), the indication of which in the bulletin allows for their identification, even without explicitly mentioning their name.

2. The respondent further states that the expression “(...)” does not reveal any health data. Health data constitutes a special category of data, according to Article 9.1 of the GDPR, the processing of which is generally prohibited, unless certain exceptions provided for in paragraph 2 of the aforementioned Article 9 of the GDPR apply.

The GDPR defines in its Article 4.15 health data as “personal data related to the physical or mental health of a natural person, including the provision of health care services, which reveal information about their health status.”

Recital 35 of the GDPR clarifies this definition by stating that “Among the personal data related to health, all data concerning the health status of the data subject that provide information about their physical or mental health past, present, or future should be included. This includes information about the natural person collected in connection with their registration for health care purposes, or in connection with the provision of such care, in accordance with Directive 2011/24/EU of the European Parliament and of the Council; any number, symbol, or data assigned to a natural person that uniquely identifies them for health purposes; information obtained from tests or examinations of a part of the body or of a bodily substance, including that derived from genetic data and biological samples, and any information relating, for example, to a disease, a disability, the risk of suffering from diseases, medical history, clinical treatment, or the physiological or biomedical status of the data subject, regardless of its source, for example, a doctor or other health professional, a hospital, a medical device, or an in vitro diagnostic test.”

The Court of Justice (CJEU) interpreted this concept broadly, considering as health-related data the information concerning all aspects, both physical and mental, of a person's health, whether related to their health status or indicating that they are in a situation of partial sick leave.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/21

(CJEU judgment of November 6, 2003, Lindqvist, C-101/01).

Moreover, the CJEU in its judgment of August 1, 2022, in case C-184/20, OT, establishes a broad interpretation of the concept of special categories of personal data:

“125 Furthermore, a broad interpretation of the concepts of ‘special categories of personal data’ and ‘sensitive data’ is supported by the objective of Directive 95/46 and the GDPR, which has been mentioned in paragraph 61 of this judgment, to ensure a high level of protection of the freedoms and fundamental rights of natural persons, in particular, their privacy, in relation to the processing of personal data that affects them (see, in this regard, the judgment of November 6, 2003, Lindqvist, C 101/01, EU:C:2003:596, paragraph 50).

126 Furthermore, a contrary interpretation would oppose the purpose of Article 8(1) of Directive 95/46 and Article 9(1) of the GDPR, which is to ensure greater protection against such processing, which, due to the particular sensitivity of the data in question, may constitute, as derived from Recital 33 of Directive 95/46 and Recital 51 of the GDPR, a particularly serious interference with the fundamental rights to respect for private life and to the protection of personal data, guaranteed by Articles 7 and 8 of the Charter [see, in this regard, the judgment of September 24, 2019, GC and others (Removal of links to sensitive data), C 136/17, EU:C:2019:773, paragraph 44].”

127 Therefore, such provisions cannot be interpreted in the sense that the processing of personal data that may indirectly reveal sensitive information about a natural person falls outside the enhanced protection regime established by the aforementioned provisions, as excluding it would undermine the useful effect of that regime and the protection of the freedoms and fundamental rights of natural

persons that it aims to guarantee.”

3. The truthfulness or otherwise of the information provided in the mobile bulletin subject to the proceedings is not questioned in this act, the assessment and consequences of which do not correspond to this Agency, nor do the powers that a municipality has to inform its citizens about matters of the corporation that are of interest to them. What is relevant to this procedure is the use made of the personal data of the claimant and whether that use complies with the applicable regulations.

4. On the other hand, the respondent states that appropriate technical measures were used in that processing. However, it has not provided any documentation to substantiate this. On the contrary, its submissions only refer to the measures it intends to implement.

5. It is also stated that, although the claimant was aware of the existence of information regarding the processing of personal data by the Municipality, which includes the manner of exercising rights in data protection matters, they have not exercised any of them. It should be noted in this regard that the possibility of filing a complaint with the supervisory authority is a right recognized for citizens that does not require, as a prior condition, the exercise of any right, unless the complaint specifically refers to the non-attention of a right, a circumstance that does not occur in this case.

#### IV

##### Article 5.1(f) of the GDPR

The facts revealed consist of the existence of a personal data breach resulting from the dissemination of personal data of the claimant through the Municipality's platform called Bando Móvil. This allowed unauthorized access by third parties to the personal data of the claimant, specifically, the (...). Regarding these facts, the respondent acts as the data controller. As such, it is obliged to demonstrate compliance with the GDPR and the LOPDGDD and to apply the technical and organizational measures that ensure the security of personal data when carrying out the processing, in accordance with the provisions of Article 5.1(f) of the GDPR, which states:

“Article 5 Principles relating to processing:

1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures (‘integrity and confidentiality’).”

In relation to this principle, Recital 39 of the aforementioned GDPR states:

“[...] Personal data must be processed in a manner that ensures adequate security and confidentiality of the personal data, including to prevent unauthorized access or use of such data and of the equipment used for processing.”

The documentation in the file provides proven facts that the respondent violated Article 5.1(f) of the GDPR regarding the principles relating to processing.

The documentation in the file provides sufficient evidence that the respondent violated Article 5.1 of the GDPR, principles relating to processing, due to a personal data breach caused by the publication of information related to the claimant indicating personal data concerning them, without having adequately ensured the confidentiality and integrity of the data.

In this regard, the aforementioned Article 5.1(f) of the GDPR provides that personal data shall be processed in such a way as to ensure their security, including protection against

11/21

unauthorized or unlawful processing and against their loss, destruction, or accidental damage, through the application of appropriate technical or organizational measures.

The loss of confidentiality poses a risk that may lead to damages, whether material or immaterial, for individuals (considering 85 of the GDPR). In this regard, considering 75 of the GDPR states: “The risks to the rights and freedoms of individuals, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing could lead to discrimination issues, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where individuals are

deprived of their rights and freedoms or prevented from exercising control over their personal data; ...". Therefore, unauthorized access to personal data implies that such data may be used for unknown, even fraudulent, purposes, resulting in a total and absolute loss of control over them.

In this same sense, Article 28.2 of the LOPDGDD, regarding the obligations of the data controller within the framework of Articles 24 and 25 of the GDPR to ensure and demonstrate that the processing is compliant with the GDPR concerning various risks, provides that:

"2. For the adoption of the measures referred to in the previous paragraph, the controllers and processors shall take into account, in particular, the greater risks that could arise in the following cases:

a) When the processing could generate situations of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic, moral, or social harm to the affected parties. ...".

And the Judgment of the Constitutional Court (STC) 292/2000 in the seventh legal foundation states:

"... it turns out that the content of the fundamental right to data protection consists of a power of disposition and control over personal data that empowers the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which data this third party may collect, and that also allows the individual to know who holds that personal data and for what purpose, being able to oppose that possession or use. These powers of disposition and control over personal data, which are part of the content of the fundamental right to data protection, are legally specified in the authority to consent to the collection, obtaining, and access to personal data, its subsequent storage and processing, as well as its possible use or uses by a third party, whether the State or a private individual."

In light of the above, the events that occurred are considered to constitute an infringement, attributable to the claimed City Council, for violation of Article 5.1.f) of the GDPR.

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

12/21

V

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringement classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines," letter a), provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% at most of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and shall prescribe after three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI



## Article 32 of the GDPR

Article 32 of the GDPR, concerning the security of processing, establishes the following:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of individuals, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to data

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](http://sedeagpd.gob.es)

13/21

personal data quickly in the event of a physical or technical incident;

- d) a process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of the processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the data processing, particularly as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union or Member State law.”

The facts revealed indicate a lack of security measures that have enabled the dissemination of personal data of the claimant on the public platform "Bando Móvil," despite lacking a legal basis for such processing.

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the appropriate technical and organizational security measures must be adequate and proportionate to the identified risk, indicating that the determination of the technical and organizational measures should be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and a verification process (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of technical and organizational security measures, particular consideration shall be given to the risks presented by the data processing, as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the costs of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may in particular cause physical, material, or immaterial damage.”

The liability of the respondent party is determined by the lack of appropriate technical and organizational measures to ensure an adequate level of security relative to the risk, as it is responsible for making decisions aimed at effectively implementing such measures. In this case, it is evident that the claimed municipality, in relation to the data being processed, does not have adequate security measures in place, regardless of the breach.

It should be emphasized that the adequacy of the level of security to the risk must be assessed by the controller and reconsidered periodically based on the results obtained, taking into account - among other factors - the risks that may arise from the unauthorized communication of such data. The technical and organizational security measures that must be applied are those relevant to respond to the existing risk, evaluating, among other factors, the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the probability and severity risks to the rights and freedoms of the data subjects.

One of the requirements established by the GDPR for controllers and processors conducting processing activities with personal data is the need to carry out a risk analysis of information security in order to establish security and control measures aimed at complying with the principles of protection by design and by default that guarantee the rights and freedoms of individuals.

The absence of adequate technical and organizational security measures, which has resulted in the dissemination of the personal data of the claimant on the public platform "Bando Móvil" accessible to all citizens of the aforementioned municipality, constitutes a violation of the provisions established in Article 32 of the GDPR.

## VII

### Classification of the infringement of Article 32 of the GDPR

The aforementioned violation of Article 32 of the GDPR constitutes the commission of the infringement classified in Article 83.4 of the GDPR "General conditions for the imposition of administrative fines," letter a), which states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a limitation period of two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure an adequate level of security relative to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679."

## VIII

### Article 9 of the GDPR

Article 4 of the GDPR defines health-related data as follows: “personal data related to the physical or mental health of a natural person, including the provision of health care services, revealing information about their health status.”

For its part, Article 9 of the GDPR establishes the following:

“1. The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data aimed at uniquely identifying a natural person, data related to health, or data related to the sexual life or sexual orientation of a natural person is prohibited.

2. Paragraph 1 shall not apply when one of the following circumstances applies:

a) the data subject has given explicit consent to the processing of such personal data for one or more specified purposes, except where Union or Member State law provides that the prohibition referred to in paragraph 1 may not be lifted by the data subject;

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

16/21

b) the processing is necessary for the fulfillment of obligations and the exercise of specific rights of the data controller or the data subject in the field of labor law and social security and protection, to the extent that it is authorized by the law of the Union of the Member States or a collective agreement under the law of the Member States that establishes adequate guarantees for the respect of fundamental rights and the interests of the data subject;

c) the processing is necessary to protect vital interests of the data subject or another natural person, in the event that the data subject is not physically or legally capable of giving consent;

d) the processing is carried out, in the context of its legitimate activities and with appropriate safeguards, by a foundation, an association, or any other non-profit organization, whose purpose is political, philosophical, religious, or trade union, provided that the processing relates exclusively to current or former members of such organizations or to persons who maintain regular contact with them in relation to their purposes and provided that the personal data is not communicated outside of them without the consent of the data subjects;

e) the processing relates to personal data that the data subject has made manifestly public;

f) the processing is necessary for the formulation, exercise, or defense of claims or when courts act in the exercise of their judicial function;

g) the processing is necessary for reasons of an essential public interest, based on the law of the Union or of the Member States, which must be proportional to the objective pursued, respect in essence the right to data protection, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject;

h) the processing is necessary for purposes of preventive or occupational medicine, assessment of the worker's capacity, medical diagnosis, provision of health or social care assistance or treatment, or management of health and social care systems and services, based on the law of the Union or of the Member States or under a contract with a health professional and without prejudice to the conditions and safeguards set out in paragraph 3;

i) the processing is necessary for reasons of public interest in the field of public health, such as the protection against serious cross-border threats to health, or to ensure high standards of quality and safety of health care and of medicines or medical products, based on the law of the Union or of the Member States that establishes adequate and specific measures to protect the rights and freedoms of the data subject, in particular professional secrecy;

j) the processing is necessary for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes, in accordance with Article 89, paragraph 1, based on the law of the Union or of the Member States, which must be proportional to the objective pursued, respect in essence the right to data protection, and establish adequate and specific measures to

protect the interests and fundamental rights of the data subject.

3. The personal data referred to in paragraph 1 may be processed for the purposes mentioned in paragraph 2, letter h), when their processing is carried out by a professional subject to the obligation of professional secrecy, or under their responsibility, in accordance with the law of the Union or of the Member States or with the standards established by the competent national authorities, or by any other person also subject to the obligation of secrecy in accordance with the law of the Union or of the Member States or the standards established by the national authorities.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/21

competent authorities.

4. Member States may maintain or introduce additional conditions, including limitations, regarding the processing of genetic data, biometric data, or health-related data.”

In the present case, despite not falling under any of the scenarios outlined in Article 9.2 of the GDPR that lift the prohibition on processing such categories of personal data, including personal data related to the health of the data subjects, the respondent has made use of health data of the claimant by including it without justification in the information published through the Bando Móvil platform, indicating that the claimant (...).

Therefore, the respondent has violated the provisions established in Article 9 of the GDPR, which prohibits the processing of health-related data unless one of the exceptions outlined in paragraph 2 of that article applies.

IX

Classification of Article 9 of the GDPR

The infringement of Article 9 of the GDPR, for which the respondent is held responsible, is classified in Article 83.5 of the GDPR:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) The basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9.”

In turn, the LOPDGDD in its Article 72.1.e) qualifies as a very serious infringement, for the purposes of prescription, “The processing of personal data of the categories referred to in Article 9 of Regulation (EU) 2016/679 without any of the circumstances provided for in that provision and in this Organic Law.”

X

Sanction

Article 83 “General conditions for the imposition of administrative fines” of the GDPR, in its paragraph 7, establishes:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

Article 77 “Applicable regime for certain categories of controllers or processors” of the LOPDGDD provides as follows:

“1. The regime established in this article shall apply to the processing for which they are responsible or processors:

a) The constitutional bodies or those with constitutional relevance and the institutions of the autonomous communities analogous to them.

b) The judicial bodies.

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that make up the Local Administration.

d) Public bodies and entities of public law linked to or dependent on the Public Administrations.

e) Independent administrative authorities.

f) The Bank of Spain.

g) Public law corporations when the purposes of the processing relate to the exercise of public law powers.

h) Public sector foundations.

i) Public Universities.

j) Consortiums.

k) The parliamentary groups of the General Courts and the Autonomous Legislative Assemblies, as well as the political groups of Local Corporations.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this Organic Law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed, with the exception of that provided for in Article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016.

The resolution shall be notified to the controller or processor, to the body to which it hierarchically depends, where applicable, and to the affected parties who had the status of data subjects, where applicable.

3. Without prejudice to the provisions of the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that apply.

Furthermore, when the infringements are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for processing that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible officer and shall order publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions relating to the measures and actions referred to in the paragraphs must be communicated to the data protection authority.

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

19/21

previous.

5. The actions taken and the resolutions issued under this article will be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.

6. When the competent authority is the Spanish Agency for Data Protection, it will publish on its website, with due separation, the resolutions related to the entities mentioned in paragraph 1 of this article, with explicit indication of the identity of the data controller or processor who committed the infringement. When the competence corresponds to an autonomous data protection authority, the publicity of these resolutions will be subject to its specific regulations.

This provision establishes that the procedures arising from infringements in the area of personal data protection committed by the categories of data controllers or processors listed in paragraph 1 will be resolved, in any case, by declaring the infringement.

## XI

### Adoption of measures

Furthermore, the aforementioned Article 77 of the LOPDGDD provides that the resolution issued may establish the measures that the infringing entity must adopt to cease the infringing conduct, correct the effects of the infringement that has been committed, and carry out the necessary adjustments, in this case, to the requirements set forth in Articles 5.1.f), 9, and 32 of the GDPR, also having to provide evidence of compliance with what is required.

Thus, the responsible entity may be required to adjust its actions to the personal data protection

regulations, to the extent expressed in the previous Legal Grounds.

In this act, the infringements committed and the facts that give rise to the violation of data protection regulations are established, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

During the processing of the sanctioning procedure, the summoned party has communicated to this AEPD the corrective measures it plans to adopt in light of the security and confidentiality incidents that are the subject of the file, among which are security measures for facilities, equipment, and services (email, web applications, and browsing), user identification and authentication, or training and awareness.

The validity of these measures is not questioned, but they are declared insufficient to the extent that none of them contemplate the establishment of mechanisms aimed at preventing incidents like the one analyzed in this case. Beyond the elimination of the Mobile Bulletin that is the subject of the complaint and the commitment to comply with personal data protection regulations, explicitly stated, there is no measure specifically aimed at preventing the dissemination of personal data through the platforms of the City Council.

Consequently, it is appropriate to require the summoned party to adopt, within three months from the date of the enforceability of this sanctioning resolution, all types of technical and organizational measures, including appropriate security measures to ensure an adequate level of security relative to the risk, in such a way that compliance with the provisions of Articles 5.1.f), 9, and 32 of the GDPR is ensured, so that the principles of integrity and confidentiality and adequate security of personal data are respected.

Among the measures to be adopted, the establishment of mechanisms prior to the dissemination of personal data may be considered so that such dissemination does not occur without a legal basis that legitimizes it.

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may motivate such conduct to open a further sanctioning administrative procedure.

Therefore, in light of the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE that the CITY COUNCIL OF MONTEMAYOR DE PILILLA, with NIF P4709400H, has infringed the provisions of Article 5.1.f) of the GDPR, Article 9 of the GDPR, and Article 32 of the GDPR, the latter infringement classified in Article 83.4 of the GDPR and the first two in Article 83.5 of the GDPR.

SECOND: TO ORDER the CITY COUNCIL OF MONTEMAYOR DE PILILLA, that pursuant to Article 58.2.d) of the GDPR, within three months from the date this resolution becomes firm and enforceable, to prove that it has adopted the necessary measures to adjust its actions to the personal data protection regulations, to the extent expressed in Legal Ground XI of this resolution; and to provide evidence to this Agency, within the same period, of the measures adopted.

THIRD: TO NOTIFY this resolution to the CITY COUNCIL OF MONTEMAYOR DE PILILLA.

FOURTH: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

21/21

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution, or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National

Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](http://sedeagpd.gob.es)